

The Contentious Chamber of the Data Protection Authority, composed of Mr. Hielke HIJMANS, president, and Messrs. Dirk Van Der Kelen and Christophe Boeraeve, members;  
Considering Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation), hereinafter "GDPR";

Considering the law of December 3, 2017, establishing the Data Protection Authority, hereinafter "LCA";

Considering the internal regulations as approved by the House of Representatives on December 20, 2018, and published in the Belgian Official Gazette on January 15, 2019;

Considering the documents in the file;

Has made the following decision regarding:

The complainant:

Mr. X, hereinafter "the complainant"; and

The defendant: Y, represented by Ms. Heidi Waem and Mr. Simon Verschaeve, whose offices are located at 1000 Brussels, rue aux Laines 70, hereinafter "the defendant".

Decision on the merits 109/2024 — 2/24

#### I. Facts and procedure

1.

On September 19, 2022, the complainant filed a complaint with the Data Protection Authority against the defendant.

2.

The complaint concerns the following facts. In December 2021, the complainant received a credit offer from the defendant in the context of purchasing a property. The credit offer includes a conditional rate reduction, one of the conditions of which is to take out a life insurance policy linked to the credit for the amount of the credit. If no remaining balance insurance is taken out with the defendant, the rate reduction is not applied. The complainant asserts that when applying for the remaining balance insurance through a broker in March 2022, it became apparent that signing a consent for the processing of health data was necessary. According to the complainant, this consent would not only apply to the medical acceptance for the remaining balance insurance in question but also to all processing of health data, such as claims processing, pricing development, refinement of affiliation and coverage conditions, and fraud detection and prevention. The complainant adds that this is also coupled with consent for automated decision-making based on health data. On March 9, 2022, the complainant received a response from the insurance broker regarding the consent for the processing of health data. This response indicated that it was impossible for the defendant to rely on more specific consent. The complainant asserts that only a remaining balance insurance is requested. The complainant notes that the defendant's website prevents the completion of the questionnaire if no consent is given. Given the risk of not benefiting from the rate reduction, the complainant gives his consent through the consent document and completes the medical questionnaire on the website. Subsequently, a summary document that must be signed via the website is prepared. According to the complainant, this summary document does not contain the same information as what was available in the fields to be completed in the questionnaire. On July 18, 2022, the complainant exercised his rights by email by partially withdrawing his consent; he also requested a limitation of processing pending clarification of the legal basis, withdrew his consent for automated decision-making, and finally requested a rectification of the signed document and sufficient integrity protection of the signed document. The complainant received a copy of his personal data from the defendant on August 12, 2022. On the same date, the complainant received from the defendant the response to the other

elements of the request.

3.

On October 21, 2022, the complaint was declared admissible by the Frontline Service based on Articles 58 and 60 of the LCA, and the complaint was forwarded to the Contentious Chamber under Article 62, § 1 of the LCA.

Decision on the merits 109/2024 — 3/24

4.

On November 17, 2022, in accordance with Article 96, § 1 of the LCA, the request from the Contentious Chamber to conduct an investigation is transmitted to the Inspection Service, along with the complaint and the inventory of documents.

5.

On March 3, 2023, the investigation by the Inspection Service is concluded, the report is attached to the file, and it is transmitted by the Inspector General to the President of the Contentious Chamber (Article 91, § 1 and § 2 of the LCA).

The report contains findings related to the subject of the complaint and concludes:

1. that, in general, there is no violation of Article 5, Article 24.1, and Articles 25.1 and 25.2 of the GDPR;
2. that there is a violation of Article 4.1 of the GDPR, Articles 7.1 and 7.3 of the GDPR, and Article 9.2.a) of the GDPR regarding the processing of health data;
3. that there is a violation of Article 22.4 of the GDPR, Article 24.1 of the GDPR, and Article 25.1 of the GDPR due to the use of automated individual decision-making for health data; and
4. that there is a violation of Article 12.1 of the GDPR, Articles 13.1 and 13.2 of the GDPR, Article 24.1 of the GDPR, and Article 25.1 of the GDPR concerning the general privacy statement regarding clients in a broad sense.

The report also includes findings that go beyond the subject of the complaint. The Inspection Service broadly finds that there is no violation of Article 38.1 and Article 39 of the GDPR.

6.

On March 22, 2023, the Contentious Chamber decides, pursuant to Article 95, § 1, 1° and Article 98 of the LCA, that the file can be processed on the merits.

7.

On March 22, 2023, the concerned parties are informed by registered mail of the provisions as set out in Article 95, § 2 as well as Article 98 of the LCA. They are also informed, pursuant to Article 99 of the LCA, of the deadlines for submitting their conclusions.

For the findings related to the subject of the complaint, the deadline for receiving the defendant's response conclusions is set for May 5, 2023, for the complainant's reply conclusions on May 26, 2023, and finally, for the defendant's reply conclusions on June 16, 2023. Regarding the findings that go beyond the subject of the complaint, the deadline for receiving the defendant's response conclusions is set for May 5, 2023.

8.

On March 23, 2023, the complainant accepts all communications related to the case electronically.

Decision on the merits 109/2024 — 4/24

9.

On March 23, 2023, the defendant agrees to receive all communications related to the case electronically and expresses its intention to exercise the right to be heard, in accordance with Article 98 of the LCA.

10.

On May 3, 2023, the Contentious Chamber receives the defendant's response conclusions regarding the findings related to the subject of the complaint. As a primary argument, the defendant asserts that the procedure and its execution by the Contentious Chamber and the Inspection Service violate the principles of good administration. As a subsidiary argument, the defendant claims that it has complied with the GDPR when processing health data based on explicit consent. These conclusions also include the defendant's reaction to the findings made by the Inspection Service outside the scope of

the complaint.

11.

On April 24, 2023, the Contentious Chamber receives the complainant's reply conclusions regarding the findings related to the subject of the complaint. The complainant requests the Contentious Chamber to address the complaint in its entirety, including the alleged violations concerning data accuracy, the right to rectification, and data integrity, even though these alleged violations were not included in the inspection report. In response to the defendant's primary conclusions, the complainant argues that, despite any alleged violations of public administration principles raised by the defendant, the Contentious Chamber can rely on the complaint and all elements presented therein to evaluate the case. In response to the defendant's subsidiary conclusions, the complainant asserts that the conditions for explicit consent for the processing of health data have not been met. Furthermore, the complainant argues that the violation concerning automated decision-making based on health data is sufficiently evidenced in the initial complaint and in the inspection report. Additionally, the complainant points out the lack of clarity regarding the basis for processing health data and the role of consent. Finally, the complainant also notes that there are violations concerning the accuracy of the personal data processed and regarding integrity and confidentiality.

12.

On June 13, 2023, the Contentious Chamber receives the defendant's reply conclusions regarding the findings related to the subject of the complaint, in which it reiterates its views from its response conclusions.

13.

On April 22, 2024, the parties are informed that the hearing will take place on June 3, 2024.

14.

On June 3, 2024, the parties are heard by the Contentious Chamber.

15.

On June 12, 2024, the minutes of the hearing are submitted to the parties.

Decision on the Merits 109/2024 — 5/24

16.

On June 5, 2024, an additional deadline was granted to the defendant to respond regarding the following points of the complaint:

a) Potential violation of Article 5.1(d) of the GDPR and Article 16 of the GDPR due to the processing of inaccurate data and the failure to comply with the right to rectify such data, given that the conditions to be omitted are no longer included in the document to be signed and that the defendant did not comply with the complainant's request to correct this.

b) Potential violation of Article 5.1(f) of the GDPR and Article 32 of the GDPR for failing to sufficiently guarantee the integrity of the data provided by using a digital signature based on public key cryptography.

17.

The deadline for receiving the defendant's response regarding the aforementioned points is set for June 28, 2024.

18.

On June 14, 2024, the Litigation Chamber received some remarks from the complainant regarding the minutes, which it decided to include in its deliberation.

19.

On June 18, 2024, the Litigation Chamber received some remarks from the defendant regarding the minutes, which it decided to include in its deliberation.

20. On June 28, 2024, the Litigation Chamber received the defendant's conclusions regarding the elements described in point 16. The defendant reiterates the arguments from its response and adds that it complies with the requirements regarding accuracy and that it has adequately addressed the exercise of the right to rectification by the complainant (Article 5.1(d) of the GDPR and Article 16 of the GDPR) and that it has taken appropriate security measures for the processing of personal data in the context of the conclusion of the outstanding balance insurance, so there is no question of a violation of Article 5(1)(f) of the GDPR and Article 32 of the GDPR.

## II. Motivation

### II.1. Principles of Good Administration

21.

First and foremost, the defendant argues that the Inspection Service violated the principles of good administration, namely the principle of motivation, the precautionary principle, the principle of reasonableness, the principle of proportionality, the principle of impartiality, and its rights of defense.

22.

The defendant asserts that based on the principle of motivation, it is necessary for the accusations to contain at least a minimum of motivation in order to understand all the circumstances of the accusations to allow it to defend itself properly.

Decision on the Merits 109/2024 — 6/24

23.

According to the defendant, the manner in which the inspection report was established violates the precautionary principle because the Inspection Service exercised its investigative powers disproportionately. Furthermore, it is the responsibility of the Inspection Service to prepare the inspection report with the necessary diligence so that the defendant clearly knows which violations are or are not upheld.

24.

Moreover, according to the defendant, the principle of reasonableness and the principle of proportionality would have been violated because the findings in the inspection report are not proportionate to the relevant facts and the subject of the complaint.

25.

Finally, the defendant claims that the principle of impartiality would also have been violated because the Inspection Service did not conduct an exculpatory investigation but rather starts from the manifest and a priori assumption of the defendant's fault.

26.

The defendant also believes that the Litigation Chamber violated the principles of good administration, including the precautionary principle, as it decided that this inspection report, which would be contrary to the principles of good administration, allows for the case to be addressed on the merits and justifies a substantive procedure.

27.

All of the aforementioned elements lead the defendant to assert that the rights of defense have been violated.

28.

In this regard, the Litigation Chamber emphasizes that procedural guarantees must be fully respected and if there had been a risk that the defendant was disadvantaged by the manner in which the inspection report was conducted, this disadvantage has been completely eliminated subsequently, which excludes any violation of the principles of good administration. The procedural elements raised by the defendant do not result in a violation of the rights of defense, as the defendant had the opportunity to present its arguments in full through its response and rebuttal; it also fully exercised its right to contradiction during the hearing of the Litigation Chamber. The defendant therefore suffered no prejudice, and the rights of defense have indeed been respected.

### II.2. Lawfulness of Processing

#### II.2.1. Findings of the Inspection Service

29.

The Inspection Service notes in its inspection report that the defendant invokes explicit consent as the legal basis for processing health data in the context of subscribing to outstanding balance insurance. However, the Inspection Service finds that the lawfulness of the processing in question has not been respected as there is a violation of Article 4.11) of the GDPR, Articles 7.1 and 7.3 of the GDPR, and Article 9.2(a) of the GDPR.

Decision on the Merits 109/2024 — 7/24

30. According to the Inspection Service, the consent that the defendant requests from the complainant

via the "consent to the processing of health data" form is not free and specific, given that the form applies to various processing purposes and that the data subjects only have the option to give their consent for all these processing purposes as a whole. Therefore, the Inspection Service finds that the consent requested via the aforementioned form is not free and specific, rendering the consent invalid in law. Finally, the Inspection Service concludes based on its investigation that it is not as easy to withdraw consent as it is to give it, as this withdrawal requires the data subject to first read the privacy statement which indicates how to proceed with this withdrawal.

#### II.2.2. Position of the Complainant

31. In his reply conclusions, the complainant asserts that the consent given was not provided in a specific and free manner. Regarding the lack of specific consent, the complainant argues that the defendant lists various purposes, such as the development of correct pricing, effective cost management, and the refinement of affiliation and coverage conditions. The defendant claims that these purposes are inextricably linked to one another. The complainant contests this and asserts that these are vaguely formulated purposes that do not specifically concern the insurance contract in question. According to the complainant, these are general activities that an insurer may engage in while managing its business, but which are not necessary for the potential large-scale use of all the health data in its possession. The complainant states that the defendant could also rely on other elements such as a subset of personal data (i.e., individuals who have given specific consent), other sources of statistical data (such as public death statistics), or scientific research.

32. The complainant adds that even if all these purposes were inextricably linked, which is denied, this link cannot justify the collection of consent for all insurance contracts. Therefore, the consent is not specific.

33. The complainant asks why the defendant, before the medical questionnaire was filled out for the outstanding balance insurance, did not briefly request consent specifically for the outstanding balance insurance in question, making the necessary distinction between the different purposes. This method would also provide the defendant with the opportunity to inform the data subject that the health data already known could also be used in determining the risk.

#### Decision on the Merits 109/2024 — 8/24

34. Regarding the free nature of consent, the complainant emphasizes that there is a certain prejudice related to the refusal of consent, which goes beyond the mere inability to obtain insurance. The complainant also criticizes the fact that, by collecting consent for different purposes within a single consent, it is not obtained freely.

35. Concerning the legal basis for the processing of health data, in the context of medical acceptance for the outstanding balance insurance, the complainant requests that the Dispute Chamber take a position regarding the legal basis, namely whether there is a sufficiently specific legal basis for the processing or if consent is the applicable legal basis. The complainant asserts that the defendant cannot be blamed for any imperfections in the legislation regarding the processing of health data in the context of medical acceptance for the outstanding balance insurance. Nevertheless, according to the complainant, the defendant must correctly define the legal basis, and if it still invokes explicit consent as the legal basis, consent must be validly requested.

#### II.2.3. Position of the Defendant

36. In its conclusions, the defendant argues that it has complied with the GDPR when processing health data based on explicit consent. It claims that explicit consent is free and specific and that it is as easy to withdraw as it is to give.

37. Regarding the specificity of explicit consent, the defendant contends that the applicable legal framework related to (life) insurance implies that the processing activities or "sub-purposes" outlined by the defendant in the consent form, which the Inspection Service considers as distinct purposes, are intrinsically linked to a single more general purpose, namely the proper fulfillment of the insurer's role in offering and executing insurance contracts. The splitting of the purpose of processing would result in either the defendant being unable to apply or respect legal principles, or creating a false impression for the concerned individual that they have the choice to granularly indicate their agreement or disagreement by processing activity or 'sub-purpose', which would be contrary to Article 5.1.a) of the GDPR, which states that "personal data must be processed lawfully, fairly, and transparently in relation

to the data subject." Given that the processing of the complainant's health data occurred solely for a single general purpose, the explicit consent obtained by the defendant is indeed specific, in accordance with the conditions set by the GDPR for the processing of personal data based on consent.

Decision on the merits 109/2024 — 9/24

38. Regarding the nature of free explicit consent, the defendant emphasizes that it follows from the legal framework concerning insurance that the processing of health data in question is not 'unnecessary' for properly fulfilling the role of insurer during the proposal and execution of insurance contracts, but must instead be considered an essential element. One cannot conclude from the finding that the defendant makes consent a condition for taking out a debt balance insurance that there is no question of a 'free' expression of will by the concerned individual and that consent is thus, by definition, invalid. The defendant highlights in this context the use of explicit consent as a ground for exception under Article 9.2.a) of the GDPR for the processing of special categories of personal data that are necessary for the performance of the contract within the meaning of Article 6.1.b) of the GDPR. This is a specific issue, particularly in Belgium and specifically for insurance companies. The defendant points out that consent as the sole ground for exception under Article 9.2 of the GDPR can apply in the absence of a national legal framework. This is in contrast to other countries in the European Union such as the Netherlands, Spain, Ireland (and the United Kingdom) where a legal framework has indeed been established for the processing of sensitive personal data by insurers. In this context, the defendant refers to legislative initiatives from the insurance sector aimed at obtaining such a legal framework, without success thus far.

II.2.4. Evaluation by the Dispute Chamber

39. The question arises as to whether the defendant can validly invoke explicit consent for the processing of personal data in the context of taking out a debt balance insurance.

40. Article 5.1.a) of the GDPR requires that personal data be "processed lawfully, fairly, and transparently in relation to the data subject ('lawfulness, fairness, transparency')." The principle of lawfulness is one of the most important principles of the GDPR and serves as a condition for the application of the other principles of the GDPR relating to the processing of personal data.

41. It is the responsibility of the data controller to determine what the appropriate legal basis is in relation to the purpose of the processing.<sup>1</sup> Given that different consequences arise from the choice of legal basis, particularly in terms of rights for the data subjects, the data controller is not permitted to rely on one or another legal basis at their discretion. Once a certain legal basis is chosen, one cannot subsequently opt for another legal basis. When the basis

<sup>1</sup> See also decision 77/2023, point 74 of the Dispute Chamber.

Decision on the merits 109/2024 — 10/24

chosen legal basis ceases to be valid, one cannot rely on another legal basis for the same processing activity, for the same purposes.<sup>2</sup>

42.

Under Article 9.1 of the GDPR, the processing of health data is generally prohibited. If there is processing of special categories of personal data in accordance with Article 9.1 of the GDPR, the data controller must designate a legal basis in accordance with Article 6 of the GDPR as well as a justification for the exception under Article 9.2 of the GDPR in order to speak of lawful processing. This combination of legal bases from Article 6 and Article 9.2 of the GDPR stems notably from the Meta judgment (C-252/21) of the Court of Justice<sup>3</sup> in which the Court expressly states that the processing of sensitive personal data is only permitted if such processing can be qualified as lawful under Article 6.1 of the GDPR. The opinion 2/2019 of the EDPB (European Data Protection Board)<sup>4</sup> and the opinion 06/2014 of the Article 29 Working Party on data protection<sup>5</sup> also logically refer to the application of both Article 6 of the GDPR and Article 9 of the GDPR in the case of processing a special category of personal data. Recital 51 of the GDPR clearly indicates that Article 6 of the GDPR must always be applied.

43. In national legislation, one cannot find an applicable legal basis either. Neither the law of July 30, 2018, on the protection of natural persons with regard to the processing of personal data<sup>6</sup>, nor the law

of April 4, 2014, on insurance<sup>7</sup>, nor any national law contains a basis for processing on which health data can be processed in the context of entering into insurance contracts. Therefore, the defendant must find a legal basis in the GDPR.

44. The EDPB guidelines 05/2020<sup>8</sup> state that Article 9.2 of the GDPR does not provide that the necessity of performing the contract can constitute an exception to the general prohibition of processing in Article 9.1 of the GDPR. In this regard, the data controller must investigate whether any of the specific exceptions in Article 9.2, under b) to j) inclusive of the GDPR could apply to such a situation. If none of the exceptions in subparagraphs b - j are applicable, obtaining explicit consent in accordance with the conditions

2 See for example decisions 38/2021, 54/2023, and 77/2023 of the Contentious Chamber.

3 CJEU, Judgment of July 4, 2023, Meta, C-252/21, ECLI:EU:C:2023:537, para. 90.

4 Opinion 3/2019 (EDPB) regarding questions and answers on the interaction between the clinical trials regulation and the General Data Protection Regulation (GDPR) [Article 70, paragraph 1, point b)] of January 23, 2019.

5 Opinion 06/2014 (Article 29 Working Party) on the concept of legitimate interest pursued by the data controller within the meaning of Article 7 of Directive 95/46/EC.

6 M.B., September 5, 2018.

7 M.B., April 30, 2014.

8 EDPB, Guidelines 5/2020 on consent under Regulation (EU) 2016/679, May 4, 2020, v.1.1 available at [https://www.edpb.europa.eu/sites/default/files/files/file1/edpb\\_guidelines\\_202005\\_consent\\_fr.pdf](https://www.edpb.europa.eu/sites/default/files/files/file1/edpb_guidelines_202005_consent_fr.pdf).

Decision on the merits 109/2024 — 11/24

of valid consent established in the GDPR is the only possible legal exception on the basis of which the data controller could process personal data concerning special categories of personal data.

45. As already mentioned above and as indicated by the defendant in its conclusions, Belgian national legislation does not provide specific legal bases for the processing of health data in the context of insurance contracts. The exceptions as provided in Article 9.2 b)-j) of the GDPR also cannot apply to the processing in question.

46. Therefore, the defendant designates Article 9.2.a) of the GDPR, namely explicit consent, as the basis for the processing of health data.

47.

In accordance with Article 9.2.a) of the GDPR, the prohibition on processing special categories of personal data does not apply if the data subject has given explicit consent to the processing of such personal data in question for one or more specific purposes. In accordance with Article 4.11) of the GDPR, "consent" of the data subject means any freely given, specific, informed, and unambiguous indication of the data subject's wishes by which they signify their agreement to the processing of personal data relating to them, either by a statement or by a clear affirmative action.

48. The element of "freely given" implies a real choice and control for the data subject. In general, the GDPR states that if the data subject is not genuinely able to exercise a choice, feels compelled to consent, or will suffer significant negative consequences if they do not give their consent, the consent is not valid.<sup>9</sup>

49. As is evident from the complaint, the credit offer in question provides for a conditional interest rate reduction, one of the conditions of which is to take out a life insurance policy linked to the credit, the aforementioned outstanding balance insurance, with the defendant up to the amount of the credit. If no outstanding balance insurance is taken out with the defendant, the interest rate reduction does not apply. Furthermore, the Disciplinary Chamber also refers to the social interest of the outstanding balance insurance, namely the benefits for spouses or heirs who are protected by taking out an outstanding balance insurance.

50. Given the negative consequences associated with not taking out the outstanding balance insurance in question, the Disciplinary Chamber considers that consent was not given freely. Since the condition of free consent has not been met, the other conditions do not need to be verified, given their cumulative nature, to assess the

9 EDPB, Guidelines 5/2020 on consent under Regulation (EU) 2016/679, May 4, 2020, v.1.1 available

at [https://www.edpb.europa.eu/sites/default/files/files/file1/edpb\\_guidelines\\_202005\\_consent\\_fr.pdf](https://www.edpb.europa.eu/sites/default/files/files/file1/edpb_guidelines_202005_consent_fr.pdf).

Decision on the merits 109/2024 — 12/24

legality of the consent in question. It is therefore a matter of a violation of Article 4.1) of the GDPR and Article 9.2 of the GDPR.

51.

The Disciplinary Chamber emphasizes, however, that this violation is not attributable to the defendant. The Disciplinary Chamber wishes to draw attention to the broader issue related to the complaint, namely the collection of health data by insurers from potential policyholders through their explicit consent (Article 9.2.a) of the GDPR) in the context of the subscription and execution of an insurance policy, specifically a loan repayment insurance, and the related question of to what extent the consent of these policyholders can be free. The question arises whether, in addition to explicit consent, there are other possible legal grounds for processing on the basis of which health data can be processed by the defendant during the execution of the insurance contract.

52.

The aforementioned law of July 30, 2018, concerning the protection of individuals with regard to the processing of personal data, which implements the GDPR, does not contain specific provisions governing in more detail the processing of sensitive personal data in the context of insurance. This is also the case for other national legislations. The defendant points out that there is a lack of a national legal framework in this regard, despite several attempts in this direction, notably initiated by the insurance sector itself. The Disciplinary Chamber can only align itself with this position and notes that the legislator should intervene in this regard to provide a specific legal basis for the insurance sector that allows for the collection of health data within well-defined limits in the context of the (pre)contractual relationship between the insurer and the insured.<sup>10</sup> The Disciplinary Chamber refers, by way of illustration, to Article 30.3.b. of the Dutch law implementing the General Data Protection Regulation<sup>11</sup>, which provides such a legal basis:

53. Article 30.3 of the [Dutch] law implementing the General Data Protection Regulation: "In view of Article 9, paragraph 2, section h of the regulation, the prohibition on processing health data does not apply if the processing is carried out by:

a. [...]

b. insurers as referred to in Article 1:1 of the Financial Supervision Act or financial service providers involved in insurance, as referred to in Article 1:1 of this law, provided that the processing is necessary for:

<sup>10</sup> See also decision 24/2020 of May 14, 2020, points 74 and 75.

<sup>11</sup> Full title: "Wet van 16 mei 2018, houdende regels ter uitvoering van Verordening (EU) 2016/679 van het Europees Parlement en de Raad van 27 april 2016 betreffende de bescherming van natuurlijke personen in verband met de verwerking van persoonsgegevens en betreffende het vrije verkeer van die gegevens en tot intrekking van Richtlijn 95/46/EG (algemene verordening gegevensbescherming) (PbEU 2016, L 119) (Law of May 16, 2018, laying down rules for the implementation of the [GDPR]).

Decision on the merits 109/2024 — 13/24

1°. the assessment of the risk to be insured by the insurer and that the data subject has not raised any objection; or

2°. the execution of the insurance contract or assistance in the management and execution of the insurance.

54. Article 30.4 of the [Dutch] law implementing the General Data Protection Regulation:

"4. If the first, second, or third paragraph applies, the data is processed only by those who, by virtue of their function, profession, or legal obligation or under a contract, are bound to secrecy. If the data controller processes personal data and is not yet subject to a confidentiality obligation under their function, profession, or a legal provision, they are bound to confidentiality regarding the data, unless the law requires them to disclose it or it follows from their tasks that the data must be disclosed to third parties who are authorized to process it under the first, second, or third paragraph." (N.B.: free translation made by the Translation Service of the Data Protection Authority, in the absence of an



official translation)

55. Despite various initiatives to provide a specific legal basis for the processing of health data in the context of insurance contracts, the Belgian legislator has yet to follow up on this.

56. The Disciplinary Chamber believes that this situation is undesirable for all parties involved in the subscription of such insurance contracts and insists that a solution be found, preferably at the European level. The Disciplinary Chamber therefore brings this decision to the attention of the EDPB, and in consultation with the Management Committee of the DPA, to the attention of other competent authorities in this matter at both the national and European levels.

### II.3. Automated individual decision-making (Article 22 of the GDPR)

#### II.3.1. Findings of the Inspection Service

57.

In the inspection report, the Inspection Service finds no violation concerning the use of automated individual decision-making for ordinary personal data.

58. Regarding the use of automated individual decision-making for health data, the Inspection Service finds that Article 22.4 of the GDPR is not respected since the consent that the defendant requested based on Article 9.2.a) of the GDPR was not validly obtained. Therefore, the Service

#### Decision on the merits 109/2024 — 14/24

of the Inspection finds that the defendant has violated Article 22.4 of the GDPR and Article 24.1 of the GDPR as well as Article 25.1 of the GDPR regarding the use of automated individual decision-making concerning health data.

#### II.3.2. Position of the complainant

59. The complainant asserts that the violation related to automated decision-making based on health data was sufficiently demonstrated in the initial complaint and was also confirmed by the Inspection Service.

#### II.3.3. Position of the defendant

60. The defendant emphasizes that the violation of Article 22.4 of the GDPR identified by the Inspection Service constitutes a 'derived' violation resulting from the violation of Article 9.2.a) of the GDPR identified by the Inspection Service and that no other violation has been raised regarding other conditions of Article 22.4 of the GDPR. Furthermore, the Inspection Service found that the defendant fully complied with the conditions of Article 22 of the GDPR concerning 'ordinary' personal data. Therefore, the defendant argues that if the Contentious Chamber finds that explicit consent was lawfully given, the violation identified by the Inspection Service regarding Article 22.4 of the GDPR should be dismissed.

61. During the hearing, the defendant was invited to further clarify its viewpoint regarding the finding related to automated individual decision-making. The defendant explained that this mode of decision-making was its deliberate choice, particularly to protect the confidentiality and integrity of medical data. When this processing yields a positive result for the client, there is no human oversight. If a potential issue arises (also referred to as a warning signal), the file is forwarded to a colleague for verification of the decision-making. Therefore, no insurance is ever denied without the decision being analyzed by a colleague of the defendant.

62. Regarding the violations of Article 24.1 of the GDPR and Article 25.1 of the GDPR, the defendant argues that these are in any case unfounded due to the lack of motivation from the Inspection Service (see section II.1). If the Contentious Chamber were to proceed with a substantive assessment of these articles, the defendant contends that it has taken all appropriate technical and organizational measures to achieve the purposes outlined by the GDPR. The defendant explains that a malfunction in a rare case does not mean that the necessary procedures and processes are not generally implemented, which the Inspection Service also notes in its first finding. Therefore, the defendant has complied with the conditions for automated individual decision-making in accordance with the requirements arising from Article 22.4 of the GDPR, Article 24.1 of the GDPR, and Article 25.1 of the GDPR.

#### Decision on the merits 109/2024 — 15/24

#### II.3.4. Assessment by the Contentious Chamber

63. When personal data is used to arrive at a certain decision and that decision is based solely on automated processing of personal data, this constitutes automated individual decision-making. Based

on Article 22.1 of the GDPR, data subjects have the right not to be subject to a decision based solely on automated processing (including profiling) when that decision has legal effects for them or similarly significantly affects them.

64. However, the above does not apply if the decision: a) is necessary for the conclusion or performance of a contract between the data subject and a data controller; b) is authorized by Union law or the law of the Member State to which the data controller is subject and which also provides for appropriate measures to safeguard the rights and freedoms and legitimate interests of the data subject; or c) is based on the explicit consent of the data subject (Article 22.2 of the GDPR).

65. Under Article 22.4 of the GDPR, automated individual decisions cannot be based on special categories of personal data unless there is explicit consent from the data subject for that purpose, or if the use is necessary for reasons of substantial public interest, based on Union law or the law of a Member State. In both cases, appropriate measures must be taken to safeguard the legitimate interests of the data subject. In the first situation, the data controller takes these measures themselves; in the second, these measures are legally prescribed.

66. As asserted by the defendant, automated individual decision-making is based on explicit consent as prescribed by Article 9.2.a) of the GDPR. In this case, the Contentious Chamber found that explicit consent had not been validly obtained, but that this infringement could not be attributed to the defendant (see section II.2). Therefore, the defendant can indeed invoke Article 22.2.c) of the GDPR in conjunction with Article 22.4 of the GDPR, provided it meets the applicable conditions.

67. Given that the defendant invokes Article 22.2.c) of the GDPR in conjunction with Article 22.4 of the GDPR, it must take appropriate measures to protect the rights of the data subject. These measures must at least include the following: the right to obtain human intervention, the right for the data subject to express their viewpoint, and the right to contest the decision.

Decision on the Merits 109/2024 — 16/24

68. Based on the defendant's statement and the privacy statement regarding decisions made in an automated manner as transmitted by the defendant, the Contentious Chamber finds that the defendant has taken various measures. Automated individual decision-making without human intervention occurs only in the case of a positive decision. If different warning signals are triggered and a negative decision must potentially be made, the file will nonetheless be submitted for review by a collaborator. The concerned individual may object to profiling so that the decision to grant credit or related debt insurance cannot be made automatically. If a concerned individual disagrees with the automated individual decision, they may, in accordance with the privacy statement, contact the defendant in several ways to express why they disagree with the decision and request a review of the decision made.

69. In light of these elements, the Contentious Chamber finds, based on the statements of the defendant and the applicable privacy statement, that the defendant lawfully bases automated individual decision-making on health data on explicit consent and has taken the appropriate measures necessary to protect the rights of the concerned individual. Since neither in the inspection report nor in the complainant's conclusions does the Contentious Chamber find any evidence that would refute this finding, the Contentious Chamber concludes that there is no violation of Article 22 of the GDPR, Article 24 of the GDPR, and Article 25 of the GDPR.

#### II.4. Information Obligations in the Privacy Statement

##### II.4.1. Findings in the Inspection Report

70. The Inspection Service finds that the general privacy statement regarding clients in a broad sense does not always contain concise, transparent, and comprehensible information (Article 12.1 of the GDPR) and, on the other hand, does not contain all the mandatory information required under Article 13 of the GDPR.

71. Regarding the information that is not always concise, transparent, and comprehensible, the Inspection Service notes that the mention in the privacy statement that the defendant is part of a group of companies does not add value. Furthermore, the Inspection Service emphasizes that the terms 'personal data' and 'data' are not synonyms that can be used interchangeably. In addition, the privacy statement contains several long and complex sentences with professional jargon, which may lack clarity for the defendant's clients who are not familiar with this subject matter.

72.

The Inspection Service considers that the privacy statement is incomplete as it does not include the direct phone number of the data protection officer (Article 13.1.b) of the GDPR). Furthermore, there is a lack of transparent information regarding the appropriate or adequate safeguards, how a copy can be obtained, or the person who can be consulted in the event of the defendant transferring personal data to third countries for which there is no adequacy decision from the European Commission (Article 13.1.f) of the GDPR). The Inspection Service also notes a lack of transparent information regarding whether the data subject is obliged to provide personal data and the potential consequences when personal data is not provided if the transmission of personal data is based on a legal or contractual obligation or if it is a necessary condition for entering into a contract (Article 13.2.e) of the GDPR).

**\*\*II.4.2. Position of the Defendant\*\***

73.

The defendant contests the findings of the Inspection Service regarding the privacy statement and refutes them in its conclusions.

74.

Regarding the findings related to information that is not always concise, transparent, and understandable, the defendant emphasizes that references to the group to which it belongs have a functional importance in explaining to the data subject how their personal data may be used within the group. Concerning the use of the terms 'data' and 'personal data', the defendant argues that it clearly communicates to the data subject that the privacy statement pertains to personal data. The term 'personal data' appears no less than 130 times in the privacy statement. It also emphasizes that the use of the term 'data' does not limit the scope of the privacy statement since, in common language and under the GDPR, this term can be understood in a broader sense than the notion of 'personal data'. Furthermore, regarding the language used in the privacy statement, the defendant asserts that the Inspection Service does not present the cited passages in their initial context, thereby omitting the information that clarifies these passages. Additionally, the defendant states that it uses the most common language possible, but given the nature of its activities and the legal framework in which it operates, it is sometimes compelled to use specific designations or terms. In accordance with Article 12.1 of the GDPR, the information addressed to the data subject must be not only clear but also concise, in order to strike an appropriate balance between adding explanations.

**Decision on the Merits 109/2024 — 18/24**

supplementary on one hand and the communication of information in a concise form on the other hand.

75.

Regarding the finding that the privacy statement would contain incomplete information, the defendant presents arguments to refute this. Concerning the absence of an indication of the direct phone number of the Data Protection Officer in the privacy statement, the defendant specifies that it chose not to mention this phone number given its notoriety in the Belgian market and the size of the company. It indeed receives a considerable number of questions and very varied requests from data subjects. It would not be feasible for the Data Protection Officer to be contacted directly by phone regarding these requests. However, data subjects can contact the defendant's helpdesk by phone. If necessary, the helpdesk agents will forward questions related to data protection to the Group Data Protection Unit, of which the Data Protection Officer is a part. Regarding information related to appropriate safeguards for transfers, the defendant claims that it explains the relevant transfers and also provides detailed information about the subcontractors with whom it collaborates. It also provides clear information to the data subject on how they can contact it and exercise their rights. In its privacy statement, the defendant first confirms its intention to transfer personal data in certain situations to recipients located (or who may be located) outside the European Economic Area. Secondly, it indicates in which countries the subcontractors are established, potentially implying possible transfers. Thirdly, it specifies that there is no adequacy decision from the European Commission for certain countries to which transfers may take place and that, if necessary, appropriate safeguards will be used, including standard contractual clauses and monitoring mechanisms to ensure the level of protection. Finally, the

defendant emphasizes that it clearly indicates in its privacy statement when the transmission of personal data is a legal or contractual obligation.

#### II.4.3. Evaluation by the Litigation Chamber

76.

In application of the principle of transparency of Article 5.1.a) of the GDPR, the data controller takes appropriate measures to provide the data subject with the information referred to in Articles 13 and 14 as well as to carry out any communication under Articles 15 to 22 inclusive and Article 34 regarding processing in a concise, transparent, comprehensible, and easily accessible manner, using clear and simple terms.

#### Decision on the Merits 109/2024 — 19/24

77.

Considering the findings of the Inspection Service and after evaluating the defendant's arguments and the privacy statement attached to the documents, the Litigation Chamber finds that there is no violation of Article 12.1 of the GDPR in conjunction with Articles 13.1 and 13.2 of the GDPR.

#### II.5. Accuracy of Data and Right to Rectification (Article 5.1.d) of the GDPR and Article 16 of the GDPR)

##### II.5.1. Position of the Complainant

78.

In his complaint, the complainant indicates that the medical questionnaire is completed via the defendant's website, with the user being guided through the questionnaire via a series of screens. Before completing the questionnaire, the user is informed that the information buttons in the questionnaire must always be used to avoid mentioning unnecessary elements. For each section in the questionnaire, there is a list of conditions that should not be mentioned. This process concludes with the establishment of a summary document that must be signed. However, this summary document lacks the enumeration of the conditions that should not be mentioned, leading the complainant to argue that the questionnaire is subject to discussion. In this regard, the complainant asserts that there is a question of whether a certain condition was omitted by the applicant or if the defendant had indicated that it was not necessary to mention this specific condition. Therefore, multiple interpretations can be given to the completed data. In this context, the complainant emphasizes that there may potentially be a dispute regarding the completed data between the defendant as the insurer and the beneficiaries of the insurance after the death of the insured. However, these beneficiaries did not complete this list and are also unaware of the initial questions and the difference between the questionnaire and the resulting summary document. According to the complainant, the accuracy of the information, given the context of the outstanding balance insurance, is extremely important, particularly due to the high financial stakes involved. Although the complainant requested it, the defendant has, according to him, made no corrections to the final document to accurately reflect the questionnaire.

##### II.5.2. Position of the Defendant

79.

In its conclusions, the defendant argues that to assist the client in completing the digital medical questionnaire and to avoid the collection of unnecessary data (and thus ensure data minimization), it has provided a limited number of 'information buttons' for certain free-text fields in its digital medical questionnaire. These information buttons indicate conditions that have no influence on the risk.

#### Decision on the merits 109/2024 — 20/24

of death and are thus by definition irrelevant at the time of completing the questionnaire.

80. The defendant emphasizes that the medical questionnaire aims to accurately assess the risk of death of the insured. Under insurance legislation, the defendant can only request, via its medical questionnaire for a remaining balance insurance, information regarding conditions that may lead to an increased risk of death, referring to Article 5.1° of the Royal Decree of April 10, 2014, regulating certain insurance contracts aimed at guaranteeing the repayment of the principal of a mortgage loan<sup>12</sup> ("Royal Decree Remaining Balance Insurance"). This article specifically sets forth the

following condition for the medical questionnaire: "the questions asked are precise and exclusively relate to events that may attest to the increased nature of a health risk concerning the insured candidate."

81.

The defendant adds that as a guarantee towards the insured, the legislator subjects the medical questionnaire of each insurer to external control. The questionnaire used by the defendant is indeed subject to prior approval by the Monitoring Office, pursuant to Article 4 of the Royal Decree Remaining Balance Insurance<sup>13</sup>.

82.

Furthermore, the defendant refers to Article 5.1.d) of the GDPR, which states that personal data must be accurate and, where necessary, kept up to date. All reasonable measures must be taken to ensure that inaccurate personal data, with regard to the purposes for which they are processed, are erased or rectified without delay. Under Article 16 of the GDPR, the data subject has the right to obtain from the data controller, without delay, the rectification of inaccurate personal data concerning them.

83. The defendant asserts that the medical questionnaire, including the information buttons, and the responses provided are recorded on its secure IT system, so that the personal data are 'accurate' within the meaning of Article 5.1.d) of the GDPR. The subsequent possibility provided by the defendant to download the questions and answers in a PDF document does not prejudice the above and does not imply that the personal data recorded in the defendant's systems would thus be inaccurate, giving the complainant the right to 'rectify' this data accordingly, within the meaning of Article 16 of the GDPR.

12 M.B., June 10, 2014.

13 Article 4 of the Royal Decree Remaining Balance Insurance: "An insurance company may only use a medical questionnaire when processing a request for remaining balance insurance if the wording of its questions has received prior approval from the Monitoring Office.

The Monitoring Office decides, within one month of receipt, on the approval of the formulation of the questions. The Monitoring Office makes its decision by a simple majority of votes."

**\*\*Decision on the Merits 109/2024 — 21/24\*\***

84. It follows from the text of the GDPR that the accuracy of personal data must be assessed in light of the purposes for which it is processed, according to the defendant. The fact that the medical questionnaire aims to allow the defendant to assess the risk of death of the insurance applicant – for which conditions that do not influence the risk of death, as indicated on the information button, are irrelevant – means that the personal data as presented in the downloadable PDF document must also be considered accurate in light of the aforementioned purpose of the processing.

85. Therefore, the defendant concludes that it is difficult to argue that there has been a disregard for the complainant's right to rectification, given firstly that the personal data must indeed be considered accurate and secondly that it responded within the time frame provided by the GDPR to the complainant's request and sought clarifications in this regard, a request that went unanswered by the complainant.

**\*\*II.5.3. Evaluation by the Litigation Chamber\*\***

86. Based on the elements provided by the defendant in the submissions, referring to the documents, the Litigation Chamber concludes that the defendant has made the required efforts to demonstrate that the accuracy of the personal data was guaranteed and that it responded correctly and in a timely manner to the complainant's rectification request, such that there is no violation of Article 5.1.e) of the GDPR and Article 16 of the GDPR.

**\*\*II.6. Integrity and Confidentiality (Article 5.1.f) of the GDPR)\*\***

**\*\*II.6.1. Position of the Complainant\*\***

87. The complainant asserts that after completing the aforementioned questionnaire accompanying the loan insurance application, a document is submitted for signature, namely the aforementioned summary document. This signature must be done via the defendant's mobile application and constitutes an essential element to ensure the integrity of the personal data. The complainant argues that without appropriate signature, it is possible for the defendant to subsequently modify the data. The complainant also indicates that the defendant, as the insurer, has a conflicting interest regarding the

data subjects (the beneficiaries).

88. When assessing whether the security is adequate, the complainant believes that the sensitivity of the personal data in question and the impact of a modification, namely a breach of data integrity, must be taken into account. The complainant claims that although there are appropriate technologies to ensure data integrity and provide proof to third parties, the defendant has not utilized them. The integrity of the document is not,

Decision on the merits 109/2024 — 22/24

According to the complainant, there is no guarantee provided by a digital signature based on public key cryptography, or this signature is, in any case, not visible to the complainant. In the absence of such a signature, the integrity of the document is not sufficiently guaranteed.

#### II.6.2. Position of the defendant

89. The defendant contests the allegations made by the complainant and asserts that it has indeed taken appropriate technical and organizational measures "to ensure a level of security appropriate to the risk," in accordance with the provisions of Article 5.1.f) of the GDPR and Article 32 of the GDPR. It is also expressly stated in Article 32 of the GDPR that the GDPR does not prescribe a single specific security measure, but that to assess the level of security, all technical and organizational measures are relevant, and that "the state of knowledge, the costs of implementation, and the nature, scope, context, and purposes of the processing as well as the risks, the likelihood and severity of which vary, for the rights and freedoms of natural persons" must also be taken into account.

90. Regarding the integrity of the digital medical questionnaire, the defendant has implemented an appropriate combination of technical and organizational measures. Once the digital medical questionnaire is completed, all responses entered by the insurance applicant are automatically captured by the system in the document that is submitted for the signature of the concerned individual. Once the signature is affixed, these data can no longer be modified in the defendant's systems. The database has been technically designed in this manner. Even if a collaborator accesses the recorded medical questionnaire under the strict access policy, this collaborator cannot modify the recorded responses of the insurance applicant that appear in the medical questionnaire within the system.

91. The defendant then outlines the main security measures regarding the integrity of the data in the medical questionnaire. These include strong authentication within the defendant's highly secure banking environment, signature with a secret PIN code or via facial recognition, timestamping of the signature, isolated storage systems where completed questionnaires are stored in an isolated database, separately from other files and processing systems of the defendant, access control for collaborators with a very strict access policy, the absence of the possibility for collaborators to modify the completed responses; completed medical questionnaires are never accessible by agencies or offices, and the internal policy includes concrete guidelines for the processing of medical data within the defendant, such as managing access to medical data and authorization to access certain applications and the retention of medical data. The defendant emphasizes that these technical and organizational measures are scrupulously followed and adjusted as necessary.

92. The defendant also emphasizes that regardless of all the previous measures, the insurance applicant can also record the medical questionnaire on their own device. The alleged risk – and purely hypothetical – of modification by the defendant mentioned by the complainant can thus, according to the defendant, simply be avoided. In such a scenario, the complainant would indeed be able, through the downloaded copy, to demonstrate a modification and provide contrary evidence, the defendant specifies. If desired, the concerned individual can also subsequently request a copy of the medical questionnaire from the defendant, as the complainant did in this case.

93. Finally, the defendant asserts that there are no specific legal requirements regarding the type of signature required for the signing of medical questionnaires, neither under the European Union eIDAS Regulation nor under Belgian law, nor under the GDPR. The defendant concludes that all the technical and organizational measures taken ensure a level of security sufficiently appropriate to the risk in accordance with the requirements of Article 5.1.f) of the GDPR and Article 32 of the GDPR.

#### II.6.3. Assessment by the Litigation Chamber

94. Based on the elements presented by the defendant in the conclusions, referring to the documents, the Litigation Chamber concludes that the defendant has made the necessary efforts to demonstrate

that the required technical and organizational measures have been taken to ensure secure data processing, so there is no violation of Article 5.1.f) of the GDPR and Article 32 of the GDPR.

### III. Publication of the decision

95. Given the importance of transparency regarding the decision-making process of the Litigation Chamber, this decision is published on the website of the Data Protection Authority. However, it is not necessary for this purpose that the identification data of the parties be directly communicated.

14 Full title: Regulation (EU) No. 910/2014 of the European Parliament and of the Council of 23 July 2014 on electronic identification and trust services for electronic transactions in the internal market and repealing Directive 1999/93/EC.